PASTA THREAT MODELING WORKSHEET

Process for Attack Simulation and Threat Analysis

PROJECT INFORMATION

Project Name: [Application/System Name]
Date: [DD/MM/YYYY]
Analyst(s): [Name(s) of Threat Modeling Team]
Version: [Document Version]
Organization: [Company/Department Name]

STAGE I: DEFINE BUSINESS AND SECURITY OBJECTIVES

Business Requirements Analysis

Make 2-3 notes of specific business requirements that will be analyzed.

Primary Business Objectives:

1. **Objective 1:** [Example: Users can create member profiles internally or by connecting external accounts]
   - **Business Impact:** [How this supports business goals]
   - **Success Metrics:** [How success is measured]
2. **Objective 2:** [Example: The app must process financial transactions]
   - **Business Impact:** [How this supports business goals]
   - **Success Metrics:** [How success is measured]
3. **Objective 3:** [Example: The app should be in compliance with PCI-DSS]
   - **Business Impact:** [How this supports business goals]
   - **Success Metrics:** [How success is measured]

Security Objectives:

- **Confidentiality Requirements:** [What data must be kept confidential]
- **Integrity Requirements:** [What data/processes must maintain integrity]
- **Availability Requirements:** [What systems must remain available]

Compliance Requirements:

- [ ] PCI-DSS
- [ ] GDPR
- [ ] HIPAA
- [ ] SOX
- [ ] Other: [Specify]

STAGE II: DEFINE THE TECHNICAL SCOPE

Technology Stack Analysis

List technologies used by the application and prioritize based on risk exposure

Core Technologies:

Technology	Description	Priority Level	Rationale
API	[Example: Application programming interface]	High	[Example: Handles sensitive data and connects various users and systems]
PKI	[Example: Public key infrastructure]	Medium	[Reasoning for priority]
SHA-256	[Example: Cryptographic hash function]	Medium	[Reasoning for priority]
SQL	[Example: Database management]	High	[Reasoning for priority]
[Technology 5]	[Description]	[High/Medium/Low]	[Reasoning for priority]

Technology Priority Justification:

High Priority Technologies:

- Technology Name: [Detailed explanation of why this technology should be prioritized, including attack surface considerations]

Medium Priority Technologies:

-

Low Priority Technologies:

-

Infrastructure Components:

- **Web Servers:** [Technology and version]
- **Database Servers:** [Technology and version]
- **Network Components:** [Firewalls, load balancers, etc.]
- **Third-party Integrations:** [External services and APIs]
- **Cloud Services:** [AWS, Azure, GCP components]

STAGE III: DECOMPOSE APPLICATION

Application Architecture

Data Flow Diagram

Create or attach a data flow diagram showing:

- **Data Stores:** [List all data repositories]
- **External Entities:** [Users, external systems, third parties]
- **Processes:** [Key application processes]
- **Data Flows:** [How data moves through the system]

[Insert Data Flow Diagram Here]

Trust Boundaries

Identify and document trust boundaries in the system:

1. **Boundary 1:** [Example: Internet to DMZ]
   - **Description:** [What this boundary protects]
   - **Security Controls:** [Firewalls, authentication, etc.]
2. **Boundary 2:** [Example: DMZ to Internal Network]
   - **Description:** [What this boundary protects]
   - **Security Controls:** [Controls in place]

Assets Inventory

Asset Type	Asset Name	Criticality	Location	Protection Level
Data	[Customer PII]	High	[Database server]	[Encryption, access controls]
Data	[Financial records]	High	[Database server]	[Encryption, access controls]
System	[Web application]	Medium	[Web server]	[Authentication, monitoring]
System	[API gateway]	High	[DMZ]	[Rate limiting, authentication]

STAGE IV: THREAT ANALYSIS

Threat Identification

List threats that are risks to the information being handled by the application

Application-Specific Threats:

1. **Injection Attacks**
   - **Description:** [Malicious code injection through input fields]
   - **Target Assets:** [Database, application logic]
   - **Attack Vectors:** [SQL injection, command injection, etc.]
2. **Session Hijacking**
   - **Description:** [Unauthorized access through session compromise]
   - **Target Assets:** [User sessions, authentication tokens]
   - **Attack Vectors:** [Session fixation, XSS, man-in-the-middle]
3. **[Threat 3]**
   - **Description:** [Description of threat]
   - **Target Assets:** [What assets are targeted]
   - **Attack Vectors:** [How the attack could be carried out]

STRIDE Analysis:

Threat Category	Examples	Affected Assets	Likelihood
Spoofing	[Identity spoofing, authentication bypass]	[User accounts, systems]	[High/Medium/Low]
Tampering	[Data modification, code injection]	[Databases, application code]	[High/Medium/Low]
Repudiation	[Denial of transactions, log manipulation]	[Audit logs, transaction records]	[High/Medium/Low]
Information Disclosure	[Data leakage, unauthorized access]	[Sensitive data, credentials]	[High/Medium/Low]
Denial of Service	[Service disruption, resource exhaustion]	[Web services, databases]	[High/Medium/Low]
Elevation of Privilege	[Privilege escalation, admin access]	[User accounts, systems]	[High/Medium/Low]

External Threat Sources:

- [ ] Nation-state actors
- [ ] Organized cybercriminals
- [ ] Hacktivists
- [ ] Insider threats
- [ ] Script kiddies
- [ ] Competitors

STAGE V: VULNERABILITY ANALYSIS

Vulnerability Assessment

List vulnerabilities that could be exploited

Identified Vulnerabilities:

1. **Lack of Prepared Statements**
   - **Vulnerability Type:** Input Validation
   - **CVSS Score:** [If available]
   - **Exploitability:** [High/Medium/Low]
   - **Impact:** [Data breach, system compromise]
   - **Affected Components:** [Database layer, SQL queries]
2. **Broken API Token**

- **Vulnerability Type:** Authentication/Authorization
- **CVSS Score:** [If available]
- **Exploitability:** [High/Medium/Low]
- **Impact:** [Unauthorized access, data exposure]
- **Affected Components:** [API endpoints, token management]

3. **[Vulnerability 3]**
   - **Vulnerability Type:** [Category]
   - **CVSS Score:** [If available]
   - **Exploitability:** [High/Medium/Low]
   - **Impact:** [Potential consequences]
   - **Affected Components:** [System components affected]

Vulnerability Categories:

OWASP Top 10 Category	Vulnerability Found	Risk Level	Components Affected
A01 - Broken Access Control	[Specific vulnerability]	[High/Medium/Low]	[Components]
A02 - Cryptographic Failures	[Specific vulnerability]	[High/Medium/Low]	[Components]
A03 - Injection	[Specific vulnerability]	[High/Medium/Low]	[Components]
A04 - Insecure Design	[Specific vulnerability]	[High/Medium/Low]	[Components]
A05 - Security Misconfiguration	[Specific vulnerability]	[High/Medium/Low]	[Components]

Technical Debt Assessment:

- **Legacy Code Issues:** [Outdated libraries, deprecated functions]
- **Configuration Problems:** [Default passwords, open ports]
- **Missing Security Controls:** [Lack of encryption, no input validation]

STAGE VI: ATTACK MODELING

Attack Scenarios

Attack Tree Analysis

Create attack trees for high-priority threats

```
[Insert Attack Tree Diagram Here]

Example Attack Tree Structure:
Goal: Steal Customer Financial Data
├── Exploit SQL Injection
│   ├── Find vulnerable input field
│   ├── Craft malicious SQL payload
│   └── Extract database contents
├── Compromise API Token
│   ├── Intercept API communications
│   ├── Extract authentication token
│   └── Use token for unauthorized access
└── Social Engineering Attack
    ├── Target system administrators
    ├── Obtain credentials
    └── Access internal systems
```

Attack Scenarios:

Scenario 1: SQL Injection Attack

- **Attack Vector:** [Vulnerable input field in web application]
- **Prerequisites:** [Web application accessible, input validation missing]
- **Attack Steps:**
  1. [Identify vulnerable parameter]
  2. [Test for SQL injection]
  3. [Extract database schema]
  4. [Exfiltrate sensitive data]
- **Success Criteria:** [Unauthorized access to customer data]
- **Detection Probability:** [High/Medium/Low]

Scenario 2: API Token Compromise

- **Attack Vector:** [Broken authentication in API]
- **Prerequisites:** [API accessible, weak token implementation]
- **Attack Steps:**
  1. [Analyze API authentication mechanism]
  2. [Identify token weaknesses]

3. [Generate or steal valid tokens]
4. [Access protected resources]

- **Success Criteria:** [Unauthorized API access]
- **Detection Probability:** [High/Medium/Low]

Kill Chain Analysis:

Phase	Attacker Actions	Defender Opportunities
Reconnaissance	[Information gathering]	[Network monitoring, threat intelligence]
Weaponization	[Exploit development]	[Vulnerability management]
Delivery	[Attack execution]	[Email filtering, web filtering]
Exploitation	[Vulnerability exploitation]	[Endpoint protection, patching]
Installation	[Malware deployment]	[Anti-malware, application whitelisting]
Command & Control	[Remote access establishment]	[Network monitoring, DNS filtering]
Actions on Objectives	[Data exfiltration]	[Data loss prevention, monitoring]

STAGE VII: RISK ANALYSIS AND IMPACT

Risk Assessment

Security Controls Assessment

List security controls that can reduce risk

Current Security Controls:

1. **SHA-256 -** Cryptographic hashing for data integrity
2. **Incident Response Procedures -** Documented response processes
3. **Password Policy -** Strong password requirements
4. **Principle of Least Privilege -** Minimal access rights assignment

Additional Recommended Controls: 5. **[Control Name] -** [Description and purpose] 6. **[Control Name] -** [Description and purpose] 7. **[Control Name] -** [Description and purpose] 8. **[Control Name] -** [Description and purpose]

Risk Matrix:

Threat	Vulnerability	Likelihood	Impact	Risk Level	Mitigation Priority
[SQL Injection]	[Lack of prepared statements]	High	High	**CRITICAL**	1
[Session Hijacking]	[Broken API token]	Medium	High	**HIGH**	2
[Threat 3]	[Vulnerability 3]	[L/M/H]	[L/M/H]	[Risk Level]	[Priority]

Risk Calculation:

Risk = Likelihood × Impact × Asset Value

Risk ID	Description	Likelihood (1-5)	Impact (1-5)	Asset Value (1-5)	Total Risk Score	Risk Level
R001	[Risk description]	[Score]	[Score]	[Score]	[Total]	[Critical/High/Medium/Low]
R002	[Risk description]	[Score]	[Score]	[Score]	[Total]	[Critical/High/Medium/Low]

Business Impact Analysis:

Financial Impact:

- **Direct Costs:** [Data breach response, regulatory fines]
- **Indirect Costs:** [Reputation damage, customer loss]
- **Estimated Total:** [$X,XXX,XXX]

Operational Impact:

- **Service Disruption:** [Downtime estimates]
- **Recovery Time:** [RTO/RPO requirements]
- **Resource Requirements:** [Personnel, systems needed for recovery]

Regulatory Impact:

- **Compliance Violations:** [Specific regulations affected]
- **Potential Penalties:** [Fines, sanctions]
- **Reporting Requirements:** [Mandatory disclosures]

MITIGATION RECOMMENDATIONS

Priority Actions:

1. **Critical (0-30 days):** [Immediate actions required]
2. **High (30-90 days):** [Important security improvements]
3. **Medium (3-6 months):** [Ongoing security enhancements]
4. **Low (6-12 months):** [Long-term security investments]

Security Control Implementation:

Control	Implementation Timeline	Cost Estimate	Responsible Party
[Implement prepared statements]	[30 days]	[$X,XXX]	[Development Team]
[Fix API token management]	[60 days]	[$X,XXX]	[Security Team]
[Control 3]	[Timeline]	[Cost]	[Owner]

APPENDICES

Appendix A: Data Flow Diagrams

[Detailed technical diagrams]

Appendix B: Attack Trees

[Complete attack tree models]

Appendix C: Risk Assessment Methodology

[Detailed explanation of risk calculation methods]

Appendix D: Security Control Mapping

[Mapping of controls to threats and vulnerabilities]

Document Prepared by: [Analyst Name]
Review Date: [DD/MM/YYYY]
Next Review: [DD/MM/YYYY]
Approval: [Manager Name and Date]

This PASTA threat model is a living document and should be updated regularly as the application evolves and new threats emerge.